JS Bank Limited

Independent Third Party IT Audit of STP Implementation

Final Report Ver. 0.2

May 2017



Building a better working world

DISCLAIMER

Documents and Information furnished by the management of JS Bank Limited (JSBL), upon which all or parts of this deliverable is based, have been assumed to be reliable and have, therefore, not been verified. Therefore, no warranty expressed or implied is given as to the accuracy of such documents/ information.

This report is made solely for JSBL, and to the extent applicable for the State Bank of Pakistan (SBP) in accordance with the methodology as defined in our proposal. It may, however, be noted that this deliverable should not be relied upon to identify all deficiencies that may exist within JSBL's IT infrastructure and environment, or to identify all areas requiring management attention. Accordingly, the comments in the deliverables refer only to those matters that have come to our attention during the course of our engagement and do not attempt to indicate all possible risks and recommendations which may be required.

We undertake that we exercised due care in the performance of our work in accordance with applicable professional standards. Our maximum liability relating to or arising from the services rendered (regardless of the form of action, whether in contract, negligence or otherwise) were limited to the related amount of fee paid to EY Ford Rhodes (EYFR), a member firm of Ernst & Young Global Limited. In no event is EYFR or its partners and personnel liable for consequential, special, incidental or punitive loss, damage or expense (including without limitation, lost profits, opportunity costs, etc.) even if it has been advised of their possible existence.

The management of JSBL will indemnify and hold harmless EYFR and its partners and personnel from and against claims, liabilities, costs and expenses (including without limitation, attorney fees and the time of EYFR's personnel involved) brought against, paid or incurred by EYFR at any time and in any way arising out of or relating to EYFR's services under this assignment, whether caused in whole or in part by EYFR's negligence, except to the extent finally determined to have resulted from the gross negligence or willful misconduct of EYFR's personnel.

Confidential - Restricted Access

Due to the sensitive nature of the various aspects (relating to IT controls) contained herein, the distribution of this document shall be limited to authorized persons on a need-to-know basis within JSBL and the State Bank of Pakistan. The document shall not be printed or photocopied without authorization.

DOCUMENT REFERENCE	
ITEM	DESCRIPTION
Document Title	Independent Third Party IT Audit of STP Implementation
Version	Final Version 2.0
Document Status	Final Submission to JSBL
Submission Date	May 26, 2017
Prepared by	EY Ford Rhodes (EYFR) Chartered Accountants *A member firm of Ernst & Young Global Limited*

Table of Contents

1. Executive Summary 4
1.1 Risk Categories 5
1.2 Scope Area Wise Risk Rating 6
2. Introduction and Background 7
3. Scope of Work 8
1.3 In-Scope Systems 9
4. Project Methodology 10
5. ITGC Audit and technical post implementation review of STP Implementation 11
6. Internal vulnerability assessment of in-scope systems 19
7. Network security review of in-scope systems 23
8. Review of Business Continuity, Disaster Recovery Plans and Testing Reports 26
9. Annexure A – Vulnerability Assessment 27
9.1 A1: Server Message Block (SMB) Protocol Version 1 Unspecified RCE (credentialed check) 27
9.2 A2: Microsoft Windows Remote Desktop Protocol Server Man-in-the-Middle Weakness 27
9.3 A3: Terminal Services Encryption Level is Medium or Low 28
9.4 A4: Terminal Services Doesn't Use Network Level Authentication (NLA) Only 28
9.5 A5: SSL Version 2 and 3 Protocol Detection 29
9.6 A6: SSL DROWN Attack Vulnerability (Decrypting RSA with Obsolete and Weakened encryption) 29
9.7 A7: SSH Server CBC Mode Ciphers Enabled 30
9.8 A8: SSL RC4 Cipher Suites Supported (Bar Mitzvah) 31
9.9 A9: Password Transmitted over HTTP 31
10. Annexure B 32
10.1 B1 - UNAUTHORIZED IDs 32

1. Executive Summary

EY Ford Rhodes was appointed by the JS Bank Limited, for carrying out Independent third party IT Audit of STP implementation. The field work for the assignment was started on March 15, 2017. Limitations and specific additional understanding, which have been agreed with the JSBL management are addressed and agreed through the Engagement Letter (EL) signed between EYFR and JSBL.

Core areas of this assignment included the following:

- ITGC Audit and technical post implementation review of STP (Straight through processing) Implementation
- End to end internal vulnerability assessment of in-scope systems
- Security review of in-scope systems, including network security, network architecture, review of configuration of network devices, firewalls, connected with the in-scope systems
- Review of BCP and IT DR plans and testing reports (if any) relevant to STP application

This report comprises the observations and recommendations relating to the scope of work. The format of our report comprises reporting on the weaknesses and exceptions noted during the review and recommendations on their remediation. The observations documented in this report are related to the areas where either control objectives are not met or where we believe improvements can be made in the efficiency or effectiveness of procedures.

Our findings and observations were discussed with JS Bank's IT Team. However, finalizing the management action plans and their implementations are not part of the scope of this assignment.

Finally, we would like to thank the management of JS Bank for the co-operation and assistance extended to us during the course of the assignment.

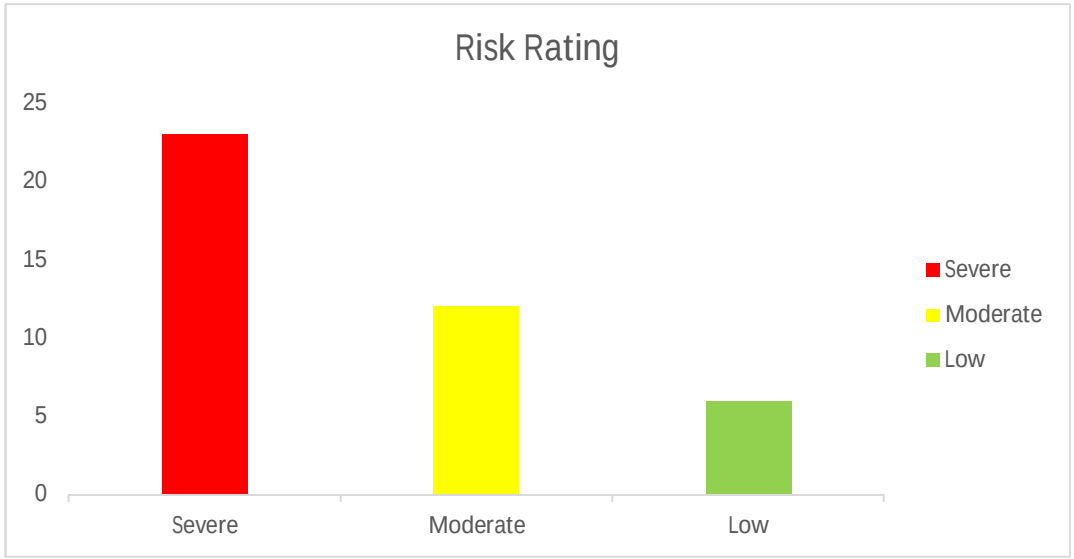
1.1 Risk Categories

In this report, each observation has been assigned a Risk rating (Severe, Moderate or Low), which should be interpreted as follows:

Risk Rating	Description
SEVERE	A significant business issue or a significant weakness in control over a key risk to the business, which requires the immediate attention of the management and priority action for resolution.
MODERATE	A business issue or control weakness, which requires the timely attention of the management, but which on its own, is unlikely to affect the adequacy and/or effectiveness of controls over key risks.
LOW	A business issue or control weakness, which has a low business risk impact. Further, issues which are addressed subsequently after the assignment time period.

1.2 Scope Area Wise Risk Rating

Risk Rating Per Area				
Scope Area	Severe	Moderate	Low	Total
ITGC Audit and technical post implementation review of STP Implementation	16	3	3	22
Internal vulnerability assessment	2	5	2	9
Review of network security, network architecture, configuration of network devices and firewalls	4	4	1	9
Review BCP and IT DR plans and testing reports	1	-	-	1
Total	23	12	6	41



2. Introduction and Background

Information is one of the most important asset of any financial institution. Protection of information assets is necessary to establish and maintain trust between the financial institution and its customers. Timely and reliable information is necessary to process transactions and support the financial institution and customer decisions. A financial institution's earnings and capital can be adversely affected if information becomes known to unauthorized parties, is altered, or is not available when it is needed. Information risk management enables a financial institution to meet its business objectives by implementing appropriate controls with due consideration of information technology (IT) related risks to the organization, business and trading partners, technology service providers, and customers.

JS Bank was formed in 2006 through the merger of American Express Bank's Pakistan branches and Jahangir Siddiqui Investment Bank Limited and in December 2016 completed its 10th year of operations. JS Bank currently operates a network of 307 branches in 152 cities. Listed on the Pakistan Stock Exchange since 2007, JS Bank is a subsidiary of Jahangir Siddiqui & Co. Limited.

The objective of this assignment is to carry out an Independent third (3rd) party IT Audit of JSBL's STP and relevant systems and networks to assess the level of risks and vulnerabilities relating to the STP application, related network(s), database(s) and Infrastructure as required by State Bank of Pakistan.

A comprehensive IT Audit and Vulnerability Assessment was performed for STP application and its relevant infrastructure. During the course of our assessment, we identified possible vulnerabilities that can be exploited by threats identified, which may cause harm to critical information systems and other vulnerabilities if any. During this exercise, considerations were made for possible vulnerabilities arising from different sources, both intrinsic and extrinsic to the asset.

3. Scope of Work

The scope envisaged the carrying out of third-party IT Audit of STP Implementation which includes the following:

- ITGC Audit and technical post implementation review of STP implementation
- End to end internal vulnerability assessment of in-scope systems
- Security review of in-scope systems, which includes network security, network architecture, review of configuration of network devices and firewalls connected with the in-scope systems.
- Review of BCP and IT DR plans and testing reports (if any) relevant to STP application

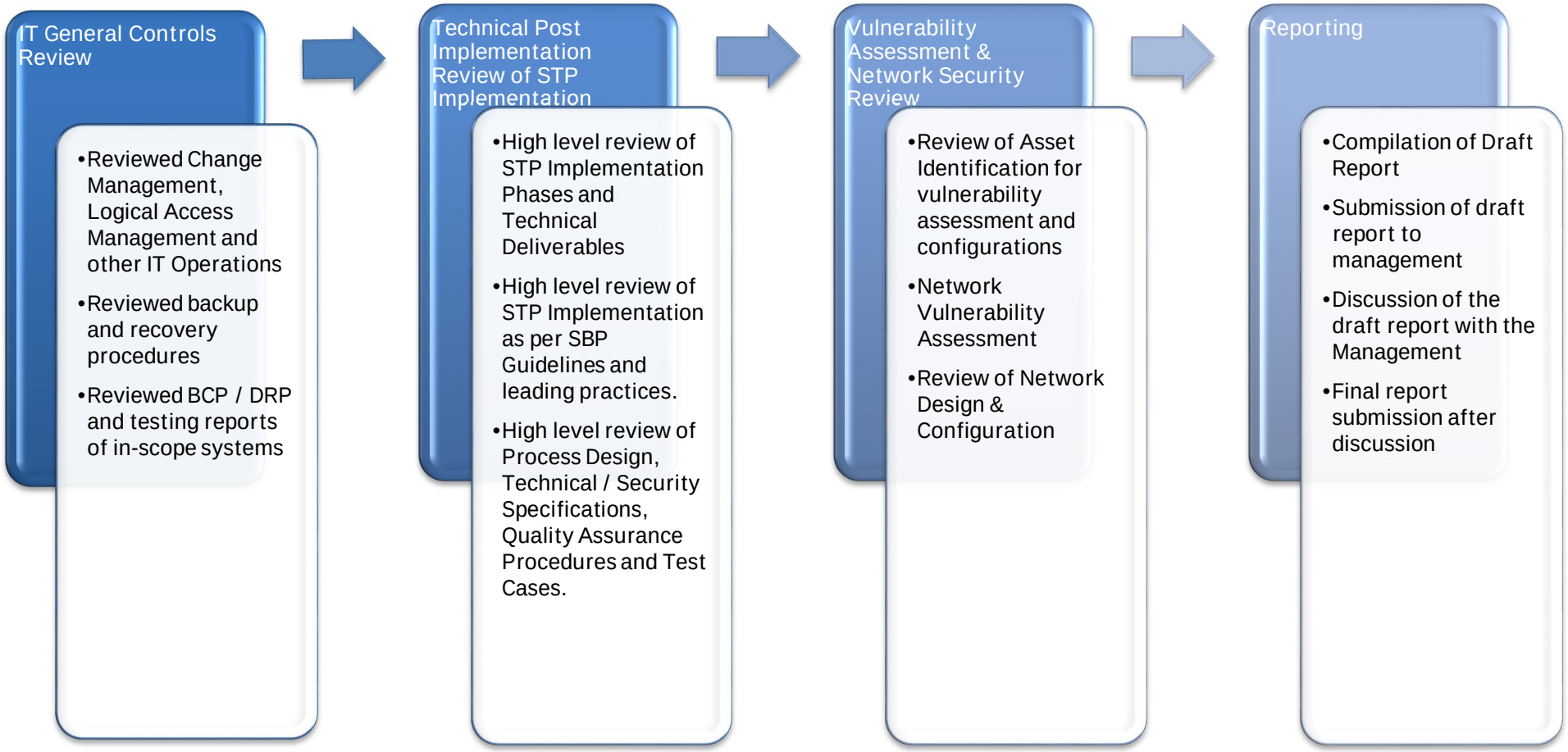
1.3 In-Scope Systems

The following are the in-scope systems identified by JSBL as per scope of work for the Independent IT Audit of STP.

Application	Application Type	Operating System	Database	Server Hardware
STP Application	Vendor Developed	Windows 7 Enterprise	Microsoft SQL Server 2008 R2 (RTM)	Dell

4. Project Methodology

EY's proven and result oriented methodology has delivered consistent, quality and holistic review through the entire lifecycle of the engagement. The following methodology was used by EY Ford Rhodes to achieve the project objectives:



5. ITGC Audit and technical post implementation review of STP Implementation

S#	Observation	Risk Rating	Affected Area	Risk and Vulnerabilities	Control Recommendations	Management Comments
1	During the review of functional specification document, we noted that STP Application Security Specifications (i.e Application Security, Activity Logging & Auditing, Integration Security, Users' & Password Security) were not defined.	Severe	STP Application	In the absence of Application's Security Specifications, vendor may not be able to develop security functionalities in the application, which could lead to the limitation for the application administrator to configure security settings as per JS Bank's information security policy and leading practices.§	Formal security specifications document should be designed in consultation with Information security group and implemented on STP application.	Will be incorporated in FSD by 10-June-2017
2	During our review, we noted that Security & Compliance review was not performed before the Go-live of the STP Application, even though it was mentioned in STP Project Plan.	Severe	STP Application	In case of nonperformance of IS review prior to the Go-live of the application, there is risk that of deploying the application, with potential security vulnerabilities, to the live environment which could cause severe security threats to the bank's security & information.	Management should implement a process which ensures that IS review is performed on the newly developed / acquired Application and approval is obtained before Go-live of the system.	Noted for Compliance. Relevant stakeholder will be notified to comply with this recommendation.
3	STP Application's Technical Administration Manual is not available for JS local IT Team for their support in performing Application's technical administration and troubleshooting tasks.	Moderate	STP Application	In the absence of technical manual of the application, the IT administrator(s) may find difficulty in performing Application's technical administration and troubleshooting tasks.	Management should ensure that STP Application's Technical Administration Manual is developed and disseminated it to the stakeholders.	Will be incorporated in FSD by 10-June-2017
4	During the review of STP Mechanism implemented at JS Bank, we noted that STP transactions messages (i.e. MT103, MT102, and MT202) created in T24 System are shared in a "Clear Text" format in "Outward Folder" located in Infobit Operating System (O/S) from which Infobit Application reads those messages and transmits them in to SBP RTGS Server. Infobit Operating System Administrator have complete rights (Edit/Write) on the "Outward Folder", where STP transactions	Severe	STP Application	There is an increased risk that confidentiality and integrity of the transactions might get compromised.	The messages shared from T24 system to STP Operating System should be stored in encrypted format so that it cannot be edited deliberately or unintentionally.	We will address this issue by looking best possibilities.

S#	Observation	Risk Rating	Affected Area	Risk and Vulnerabilities	Control Recommendations	Management Comments
	messages (i.e. MT103, MT102, and MT202) are shared.					
5	STP Application related users' complaints are not logged in Help Desk System for proper tracking/ management of the STP issues and errors after Application's GO-Live.	Low	STP Application	In the absence of appropriate help desk system, it will be difficult for the management to track/ monitor the status of STP related issues and errors. Additionally there is a risk that the technical support personnel may not be able to provide adequate and timely assistance to users. Further, management may not be able to track and monitor statistics pertaining to STP issues after the GO-Live / Pilot Run encountered by users.	STP related issues and problems should be logged and recorded in JS Banks IT Help Desk System to ensure that all such events are recorded, analysed and resolved in a timely manner.	Noted for Compliance
6	During STP Application Access Management Review, we noted the violation of Segregation of Duties; as business user from Treasury Department is currently assigned and engaged in the Creation and Modification of Users Rights, Unlocking of Users ID's and Resetting of passwords. Moreover, the same business user have been assigned, and using another STP Application ID (shakil00078) to View and Authorize STP Transactions.	Severe	STP Application	Lack of segregation of duties between application administration and application business transactions may result in inefficiencies and weakens the General Control environment within the bank. This could result in unwarranted provision / modification of access rights to users on STP application.	Application administrative responsibility should be revoked from Treasury department and assigned to centralized user administration department.	Point noted, as we are working on it to transfer the Application Administrative responsibilities to the relevant department ASAP
7	During Access Management review, we noted that Generic STP Administration User IDs "sec_maker" and "sec_checker" are used for User Administration tasks.	Sever	STP Application	Generic user IDs are the primary targets of intruders attempting to gain access to the information resources; the unauthorized user may attempt to gain access to the Application,	The generic ID should be disabled. Further, named IDs must be created and "sec_maker" and "sec_checker" roles should be assigned to ensure	Noted for Compliance

<table>
<tr><th>S#</th><th>Observation</th><th>Risk Rating</th><th>Affected Area</th><th>Risk and Vulnerabilities</th><th>Control Recommendations</th><th>Management Comments</th></tr>
<tr><td></td><td></td><td></td><td></td><td>compromising the security of systems and the information stored in it. Further, accountability could not be established if malicious activities are performed using generic user IDs.</td><td>traceability and accountability.</td><td></td></tr>
<tr><td>8</td><td>During Access Management review, we noted that, STP Application has the limitation that, Create Message rights for specific transaction type (e.g. MT 102) cannot be assigned to a user. System only allows to assign the role of “Creator” to the user, as a result users gains the message creation rights of all the transaction messages such as MT102, MT103, MT202, and MT199 available the STP Application.

During review we identified the following users, who have the message creation rights of all the above mentioned transactions. Further, the description of creation rights are also not defined in the User Account forms at the time of approval:

<table><tr><th>ID</th><th>USR_NAME</th><th>ROLE</th><th>DEPT</th></tr><tr><td>38</td><td>kumail05072</td><td>Creator</td><td>Treasury</td></tr><tr><td>39</td><td>abdul02494</td><td>Creator</td><td>Treasury</td></tr><tr><td>41</td><td>omair01664</td><td>Creator</td><td>Treasury</td></tr><tr><td>45</td><td>kashif00076</td><td>Creator</td><td>Treasury</td></tr><tr><td>46</td><td>naeem01847</td><td>Creator</td><td>Treasury</td></tr><tr><td>40</td><td>waseem02788</td><td>Creator</td><td>Treasury</td></tr><tr><td>48</td><td>azam03852</td><td>Creator</td><td>Treasury</td></tr><tr><td>47</td><td>hasnain03408</td><td>Creator</td><td>Treasury</td></tr><tr><td>49</td><td>adnan00077</td><td>Creator</td><td>Treasury</td></tr></table></td><td>Severe</td><td>STP Application</td><td>There is a risk that users have excessive rights that are not compatible with their job functions.</td><td>STP application user administration functionality should be upgraded which allows administrator to assign specific transaction messages creation rights to the users. Further, Management should ensure that only restricted rights are assigned to the user IDs based on their job functions.</td><td>We will address this issue and fix the same till 10-July-2017</td></tr>
<tr><td>9</td><td>During Access Management review, we found the following external Vendor’s IDs active in the STP Application Production</td><td>Severe</td><td>STP Application</td><td>In case where the vendor accesses the production environment and there is no</td><td>Management should ensure that vendor’s activities are restricted to the test</td><td>Vendor access on Production environment will be revoked</td></tr>
</table>

<table>
<tr><th>S#</th><th>Observation</th><th>Risk Rating</th><th>Affected Area</th><th>Risk and Vulnerabilities</th><th>Control Recommendations</th><th>Management Comments</th></tr>
<tr><td></td><td>Environment. Moreover, there is no authorization available for the below mentioned STP Application IDs. Further, there is no process in place to monitor the transactions performed by vendor IDs in the live environment.
<table>
<tr><th>ID</th><th>USR_NAME</th><th>ROLE</th><th>DEPT</th></tr>
<tr><td>35</td><td>as</td><td>Viewer</td><td>Treasury</td></tr>
<tr><td>6</td><td>Usama</td><td>Viewer</td><td>Centralized Operations-COPS</td></tr>
<tr><td>24</td><td>Faaaa</td><td>Viewer</td><td>Centralized Operations-COPS</td></tr>
</table></td><td></td><td></td><td>process to monitor their activities, there is a risk that unauthorized transactions will be performed in production application and/or data may go undetected.</td><td>environment of STP Application. Where required, vendor's activities on production environment should be logged and reviewed by an Independent authority to ensure that only authorized transactions are made by the vendor.</td><td></td></tr>
<tr><td>10</td><td>During Access Management Review, we found that following IDs of Test System were active in STP Application Production Environment. Hence there is No Authorization available for the below mentioned IDs:
<table>
<tr><th>USR_ID</th><th>USR_NME</th><th>ROLE_NME</th><th>DEPT_NME</th></tr>
<tr><td>56</td><td>adnan77</td><td>Viewer</td><td>Treasury</td></tr>
<tr><td>30</td><td>shakil1</td><td>Viewer</td><td>Treasury</td></tr>
<tr><td>36</td><td>hafeezuddin</td><td>Viewer</td><td>Treasury</td></tr>
</table></td><td>Severe</td><td>STP Application</td><td>Without formal authorization of user access, management cannot be assured that user access is appropriate and proper approvals were obtained before such access was granted.</td><td>Test IDs from production system should be deleted / disabled. Furthermore, User IDs should be only be formed based on the formal authorization forms approved by the relevant business head(s).</td><td>Test IDs on Production environment will be deleted</td></tr>
<tr><td>11</td><td>Following generic IDs were active in STP Application:
<table>
<tr><th>USR_ID</th><th>USR_NME</th><th>ROLE_NME</th><th>DEPT_NME</th></tr>
<tr><td>8</td><td>creator</td><td>creator</td><td>Treasury</td></tr>
<tr><td>7</td><td>sec_makero</td><td>Viewer</td><td>Treasury</td></tr>
<tr><td>1</td><td>maker</td><td>Viewer</td><td>Centralized Operations-COPS</td></tr>
<tr><td>2</td><td>sec_maker</td><td>Viewer</td><td>Treasury</td></tr>
<tr><td>3</td><td>sec_checker</td><td>Security Authorizer</td><td>Treasury</td></tr>
<tr><td>16</td><td>Sec_makersssss</td><td>Viewer</td><td>Centralized Operations-COPS</td></tr>
<tr><td>17</td><td>Sec_makersade</td><td>Authorizer</td><td>Centralized Operations-COPS</td></tr>
<tr><td>8</td><td>Sec_makerasd</td><td>Creator</td><td>Treasury</td></tr>
</table></td><td>Severe</td><td>STP Application</td><td>Generic user IDs are the primary targets of intruders attempting to gain access to the information resources; the unauthorized user may attempt to gain access to the Application, compromising the security of systems and the information stored in it. Further, accountability could not be established if malicious activities are performed using generic user IDs.</td><td>The generic ID should be deleted / disabled. Individual user accounts and passwords must be set up to ensure traceability and accountability.</td><td>Generic IDs will be deleted & individual user accounts will be created to ensure traceability and accountability</td></tr>
</table>

<table>
<tr><th>S#</th><th>Observation</th><th>Risk Rating</th><th>Affected Area</th><th>Risk and Vulnerabilities</th><th>Control Recommendations</th><th>Management Comments</th></tr>
<tr><td>12</td><td>During Access Management Review, we found following Duplicate IDs were active in STP Application:
<table>
<tr><th>USR_ID</th><th>USR_NME</th><th>ROLE_NME</th><th>DEPT_NI</th></tr>
<tr><td>25</td><td>Hafeez</td><td>Viewer</td><td>Treasur</td></tr>
<tr><td>26</td><td>Hafeez1</td><td>Creator</td><td>Treasur</td></tr>
<tr><td>33</td><td>Shafeez</td><td>Viewer</td><td>Treasur</td></tr>
<tr><td>36</td><td>hafeezuddin</td><td>Viewer</td><td>Treasur</td></tr>
<tr><td>54</td><td>Hafeez00052</td><td>Viewer</td><td>Treasur</td></tr>
<tr><td>55</td><td>Yaqoob00031</td><td>Viewer</td><td>Treasur</td></tr>
<tr><td>14</td><td>Yaqoob0031</td><td>Viewer</td><td>Centraliz Operations-</td></tr>
<tr><td>57</td><td>iftikhar1552</td><td>Viewer</td><td>Treasur</td></tr>
<tr><td>11</td><td>iftikhar1552</td><td>3</td><td>-</td></tr>
<tr><td>4</td><td>responder</td><td>3</td><td>Treasur</td></tr>
<tr><td>6</td><td>responder</td><td>3</td><td>ICU</td></tr>
<tr><td>10</td><td>usama</td><td>Creator</td><td>Treasur</td></tr>
<tr><td>6</td><td>Usama</td><td>1</td><td>-</td></tr>
</table></td><td>Severe</td><td>STP Application</td><td>Having duplicate IDs for a single user gives the user an opportunity to work around and breach the controls implemented at organizational level to ensure segregation of duties.</td><td>A detailed review should be performed of the existing user IDs created in the application, which should cover the area of segregation of duties enforced within the application.

A user should only be assigned a single ID with the appropriate level of access specific to the job role.</td><td>Duplicate IDs will be deleted & rights will be assigned to single user ID as per job role</td></tr>
<tr><td>13</td><td>During the Access Management Review, we noted that User Request forms against 23 user IDs were not available. Please refer Annexure B for the list of IDs.</td><td>Severe</td><td>STP Application</td><td>Without formal authorization of access requests, management cannot be assured that user access is appropriate and proper approvals were obtained before such access was granted.</td><td>Formal documentation / Access Request Form of user access should be retained to ensure that user access is appropriate and proper approvals were obtained before such access was granted.</td><td>We will remove all the unapproved IDs from system till 20-June-2017</td></tr>
<tr><td>14</td><td>Following password settings are not configured in the STP application:

a. Minimum length of password is not configured in the application as per Information Security policy.

b. First password does not require forced change as per the requirement of Information Security policy.

c. Password expiry days' parameter is not</td><td>Severe</td><td>STP Application</td><td>Weak passwords increase the risk of someone gaining unauthorized access to system using commonly available password cracking utilities.</td><td>Password settings should be configured as per the clause number 8.8 of the Information Security Policy.</td><td>We will implement password complexity policies till 15-June-2017</td></tr>
</table>

S#	Observation	Risk Rating	Affected Area	Risk and Vulnerabilities	Control Recommendations	Management Comments
	configured in the application as required by the Information Security policy. d. Password complexity has not been configured in the application as per Information security policy. e. Password history is not maintained as per the Information Security policy.					
15	Activity audit logging functionality for privileged users is not programmed in the application.	Severe	STP Application	If activities of privileged user accounts are not being logged, the integrity and confidentiality of the data may be compromised. Further, the management cannot track fictitious activities of privileged users.	Activities of privileged user accounts should be logged, monitored & reviewed periodically by an independent security team.	We will build activity logging in application. The target date would be suggested after technical review
16	During the review of change request (Patch) deployed on the STP Production System, dated 30-03-2017, we identified that the change was not reviewed and signed off by the Information Security and IT Risk Management Group before deployment on STP Production System. However, JS Bank's Change Control policy as mentioned in the section 8.18 of the Information Security Policy states that, Risk analysis is required to ensure residual risk at acceptable level. All changes must undergo an IT risk review to ensure that the system MUST comply with security baseline requirements at a minimum even after change implementation.	Severe	STP Application	In the absence of Information Security review over the development of changes on production systems, there remains the threat of deploying vulnerable codes/build in to the live environment which could cause severe security threats to the organization's security & information.	All changes going to be deployed on production system must undergo an IT risk review to ensure that the system MUST comply with security baseline requirements at minimum even after change implementation.	Infosec will review all the future changes
17	During the review we noted that Windows 7 Enterprise default "Administrator" generic ID is used by multiple IT personnel for the system administration and change	Severe	STP Operating System	If production environment is used by multiple persons using generic "Administrator" ID, there is a risk to make	Windows 7 Enterprise "Administrator" generic ID should be Escrowed and named privileged ID's should	Individual IDs will be created to al technical stake holders.

S#	Observation	Risk Rating	Affected Area	Risk and Vulnerabilities	Control Recommendations	Management Comments
	deployment tasks on STP Server. As a result, Segregation of Duties and Accountability cannot be established between the Jobs of IT personnel.			unauthorized and/or inappropriate changes to the application which could affect the processing of the application functions. Further, it would be difficult to establish accountability in such situations, if generic ID's are in use for system administration tasks.	be created in STP server for the deployment of changes and other administrative tasks.	
18	There is no automated change management tool used for STP Application to track, monitor and record changes implemented in STP application.	Low	STP Application	In the absence of automated change management tool and system generated change logs, it will be difficult for management to perform reviews/audits of previous changes and validate that no unauthorized changes were made to the live environment.	The management should consider the implementation of automated tool for change management of STP Application to better control the change management cycle for its business applications. This tool should cover system generated change log along with version allocated with time stamp.	We will open ticket for all future changes in Mantis for Change management.
19	During the review of STP Database and Operating System, we noted that SQL Server and Windows 7 Enterprise Administrator privileged accounts activities are not monitored on regular basis by independent reviewer with assistance from centralized SIEM system.	Moderate	STP Database / Operating System	If activities of privileged users are not logged and monitored, the integrity and confidentiality of the data may be compromised. OS and DB Administrator Accounts have access to Application's data files, utilities, security etc. and has the ability to change the database/ operating characteristics and parameters. In the absence of a formal independent and timely review of activity logs, any unauthorized changes to the system may not be detected	Activities of OS and DB Administrator Accounts should be logged, managed and reviewed by the independent authority at regular intervals of time with assistance from centralized SIEM system.	We will add this machine in SIEM by 20-June-2017
20	During the review of STP Database, we noted that SQL Server default Administrator "SA" is enabled and none of	Severe	STP Database	"SA" default Administrator Account provides unlimited access to entire SQL Server	It is recommended to enforce strong password policy as per guidelines of JS	Rectified. We have already and implement the same.

S#	Observation	Risk Rating	Affected Area	Risk and Vulnerabilities	Control Recommendations	Management Comments
	the Password Security Settings has been configured in SQL Server for the "SA" account.			utilities, programs and data, and therefore its use provides unlimited opportunity to compromise system security. Easily guessable and poor password usage increases the risk of an individual gaining unauthorized access to an organization's information assets and network resources. Easily guessable passwords are one of the most common mechanisms for compromising an account using commonly available password cracking utilities.	Bank's Information Security Policy. The password for SA should be changed and placed in a sealed envelope under robust physical controls and should only be used in exceptional circumstances.	
21	During the review of STP Database, we noted that generic SQL Server Accounts such as "Infobits" and "INFB" exists and are in use for different SQL Server administrative tasks.	Moderate	STP Database	Generic user IDs are the primary targets of intruders attempting to gain access to the information resources; the unauthorized user may attempt to gain access to the Application, compromising the security of systems and the information stored in it. Further, accountability could not be established if malicious activities are performed using generic user IDs.	The generic ID's should be disabled. Further, named IDs must be created and assigned relevant SQL Server Privileges and roles to ensure traceability and accountability.	Rectified. As discussed these are service accounts.
22	During the review of STP Database, we noted that SQL Server "Login Auditing" configuration is set to "Failed Logins Only".	Low	STP Database	Activity Audit Logging and Monitoring of users with successful DB Logins cannot be performed.	Login Auditing Configurations to "Both Failed and Successful Logins"	We will implement this by 29-May-2017

6. Internal vulnerability assessment of in-scope systems

#	Observation	Risk	Affected Nodes	Risk and Vulnerabilities	Control Recommendations	Management Comments
1	Server Message Block (SMB) Protocol Version 1 Unspecified RCE (credentialed check)	Severe	10.111.100.107 tcp /445	The remote Windows host is affected by an unspecified remote code execution vulnerability in SMBv1. The remote Windows host supports Server Message Block (SMB) Protocol version 1. It is, therefore, affected by an unspecified remote code execution vulnerability that allows an unauthenticated, remote attacker to execute arbitrary code. This vulnerability is one of multiple Equation Group vulnerabilities and exploits disclosed by a group known as the Shadow Brokers. See Annexure : A1	Disable SMBv1 according to the vendor instructions in Microsoft KB2696547. Additionally, block SMB directly by blocking TCP port 445 on all network boundary devices. For SMB over the NetBIOS API, block TCP ports 137 / 139 and UDP ports 137 / 138 on all network boundary devices. This advisory is available at the following link: https://support.microsoft.com/en-us/kb/2696547	Noted for Compliance
2	Password Transmitted over HTTP	Severe	10.111.100.107 tcp /80	The password data is being transmitted over HTTP. If an attacker can intercept network traffic, he/she can steal users' credentials. See Annexure : A9	All sensitive data should be transferred over HTTPS rather than HTTP. Forms should be served over HTTPS. All aspects of the application that accept user input, starting from the login process, should only be served over HTTPS.	Noted for Compliance
3	Microsoft Windows Remote Desktop Protocol Server Man-in-the-Middle Weakness CVE-2005-1794	Moderate	10.111.100.107 tcp / 3389	It may be possible to get access to the remote host. The remote version of the Remote Desktop Protocol Server (Terminal Service) is vulnerable to a man-in-the-middle (MiTM) attack. The RDP client makes no effort to validate the identity of the server when setting up encryption. An attacker with the ability to intercept traffic from the RDP server can establish encryption with the client and server without being detected. A MiTM attack of this nature would allow the attacker to obtain any sensitive information transmitted, including authentication credentials.	- Force the use of SSL as a transport layer for this service if supported, or/and - Select the 'Allow connections only from computers running Remote Desktop with Network Level Authentication' setting if it is available. This advisory is available at the following link: http://www.oxid.it/downloads/rdp-gbu.pdf http://technet.microsoft.com/en-us/library/cc782610.aspx	Rectified. We have enabled Network Level Authentication

#	Observation	Risk	Affected Nodes	Risk and Vulnerabilities	Control Recommendations	Management Comments
				This flaw exists because the RDP server stores a hard-coded RSA private key in the mstlsapi.dll library. Any local user with access to this file (on any Windows system) can retrieve the key and use it for this attack. See Annexure :A2		
4	Terminal Services Encryption Level is Medium or Low	Moderate	10.111.100.107 tcp / 3389	The remote host is using weak cryptography. The remote Terminal Services service is not configured to use strong cryptography. Using weak cryptography with this service may allow an attacker to eavesdrop on the communications more easily and obtain screenshots and/or keystrokes. See Annexure : A3	Change RDP encryption level to one of : 3. High 4. FIPS Compliant	Rectified.
5	Terminal Services Doesn't Use Network Level Authentication (NLA) Only	Moderate	10.111.100.107 tcp /3389	The remote Terminal Services doesn't use Network Level Authentication only. The remote Terminal Services is not configured to use Network Level Authentication (NLA) only. NLA uses the Credential Security Support Provider (CredSSP) protocol to perform strong server authentication either through TLS/SSL or Kerberos mechanisms, which protect against man-in-the-middle attacks. In addition to improving authentication, NLA also helps protect the remote computer from malicious users and software by completing user authentication before a full RDP connection is established. See Annexure :A4	Enable Network Level Authentication (NLA) on the remote RDP server. This is generally done on the 'Remote' tab of the 'System' settings on Windows. This advisory is available at the following link: http://technet.microsoft.com/en-us/library/cc732713.aspx	Rectified. We have enabled Network Level Authentication
6	SSL Version 2 and 3 Protocol Detection	Moderate	10.1.100.40 tcp / 443	The remote service encrypts traffic using a protocol with known weaknesses. The remote service accepts connections encrypted using SSL 2.0 and/or SSL 3.0. These versions of SSL are affected by several cryptographic flaws. An attacker can exploit these	Consult the application's documentation to disable SSL 2.0 and 3.0. Use TLS 1.1 (with approved cipher suites) or higher instead. This advisory is available at the following link: http://www.schneier.com/pa	Noted for Compliance

#	Observation	Risk	Affected Nodes	Risk and Vulnerabilities	Control Recommendations	Management Comments
				flaws to conduct man-in-the-middle attacks or to decrypt communications between the affected service and clients. NIST has determined that SSL 3.0 is no longer acceptable for secure communications. As of the date of enforcement found in PCI DSS v3.1,any version of SSL will not meet the PCI SSC'S definition of 'strong cryptography'. See Annexure : A5	per-ssl.pdf http://support.microsoft.com/kb/187498 https://www.openssl.org/~bodo/ssl-poodle.pdf https://www.imperialviolet.org/2014/10/14/poodle.html https://tools.ietf.org/html/draft-ietf-tls-downgrade-scsv-00	
7	SSL DROWN Attack Vulnerability (Decrypting RSA with Obsolete and Weakened encryption) CVE-2016-0800	Moderate	10.1.100.40 tcp / 443	The remote host may be affected by a vulnerability that allows a remote attacker to potentially decrypt captured TLS traffic. The remote host supports SSLv2 and therefore may be affected by a vulnerability that allows a cross-protocol Bleichenbacher padding oracle attack known as DROWN (Decrypting RSA with Obsolete and Weakened eNcryption). This vulnerability exists due to a flaw in the Secure Sockets Layer Version 2 (SSLv2) implementation, and it allows captured TLS traffic to be decrypted. A man-in-the-middle attacker can exploit this to decrypt the TLS connection by utilizing previously captured traffic and weak cryptography along with a series of specially crafted connections to an SSLv2 server that uses the same private key. See Annexure : A6	Disable SSLv2 and export grade cryptography cipher suites. Ensure that private keys are not used anywhere with server software that supports SSLv2 connections This advisory is available at the following link: https://drownattack.com/ https://drownattack.com/drown-attack-paper.pdf	Windows 7 does not support but we configure the policy Set Client Connection Encryption Level as High
8	SSH Server CBC Mode Ciphers Enabled CVE-2008-5161	Low	10.1.100.40 10.1.100.90 tcp/22	The SSH server is configured to use Cipher Block Chaining. The SSH server is configured to support Cipher Block Chaining (CBC) encryption. This may allow an attacker to recover the plaintext message from the cipher text.	Contact the vendor or consult product documentation to disable CBC mode cipher encryption, and enable CTR or GCM cipher mode encryption.	Noted for Compliance

#	Observation	Risk	Affected Nodes	Risk and Vulnerabilities	Control Recommendations	Management Comments
				See Annexure : A7		
9	SSL RC4 Cipher Suites Supported (Bar Mitzvah) CVE-2015-2808 CVE-2013-2566	Low	10.1.100.40 tcp / 443	The remote service supports the use of the RC4 cipher. The remote host supports the use of RC4 in one or more cipher suites. The RC4 cipher is flawed in its generation of a pseudo-random stream of bytes so that a wide variety of small biases are introduced into the stream, decreasing its randomness. If plaintext is repeatedly encrypted (e.g., HTTP cookies), and an attacker is able to obtain many (i.e., tens of millions) cipher texts, the attacker may be able to derive the plaintext. See Annexure : A8	Reconfigure the affected application, if possible, to avoid use of RC4 ciphers. Consider using TLS 1.2 with AES-GCM suites subject to browser and web server support. This advisory is available at the following link: http://www.isg.rhul.ac.uk/tls/ http://www.imperva.com/docs/HII_Attacking_SSL_when_using_RC4.pdf	Noted for Compliance

7. Network security review of in-scope systems

#	Observation	Risk	Affected Nodes	Risk and Vulnerabilities	Control Recommendations	Management Comments
1	During our network Review it has been noted that no firewall is placed between core banking sever and Integration API server as per the Network Diagram. We also noted that multiple server are running on same VLAN as API server.	Severe	STP Network	There is a high risk that sensitive data may be compromised if any of the server on the same VLAN compromises due to any security breach.	There should be segregation of different VLAN's. API server should be on a separate VLAN. A firewall should be deployed between core banking server and Integrated API server as recommended by SBP.	Network will be segregated by configuring separate VLAN by end of June, 2017.
2	During review of configuration file, we noted that Fortinet 60D firmware is not updated to latest firmware.	Severe	10.1.100.90 (Fortinet 60D)	There is a high risk that firewall may be vulnerable to security threats and zero-day exploits due to non-updated firmware. Also, there is an increased risk that an unauthorized user may gain access to the firewall if vendor security patches and upgrades are not applied in a timely manner.	Firmware of the firewall should be updated to the latest version as recommended by the manufacturer. For information Refer Fortinet 60D support link: http://docs.fortinet.com/d/supported-upgrade-paths-to-fortios-5.2	Currently we are using stable version 5.2 which is recommended by Fortinet and is available for support. This version also supports all security features. We will upgrade the version as soon as latest version will become mature and recommended will be provided by vendor.
3	During review of configuration file, it has been observed that firewall rule (Any, Any, Any) is implemented which means that packet can travel from any source to any destination on any port. In configuration file Policy ID2 states that untrusted to trusted communication is permitted with any source to any destination.	Severe	10.1.40.100 (Juniper SSG20)	If network filtering rules are not configured to restrict access to network services from only authorized hosts then unauthorized access may be granted to unauthorized users. For a network edge device, this could lead to a remote attacker gaining access to network service.	All network filtering rules should be configured to restrict access from authorized hosts only.	Rectified.
4	During Review of configuration file, it has been observed that Default account name "admin" is used with super user rights, which is a clear indication to any attacker that this user	Severe	10.1.100.90 (Fortinet 60D) 10.1.100.40 (Juniper SSG20)	Malicious individuals often use vendor default username/IDs to compromise network devices because these defaults username/IDs are frequently published on internet. Once an	All administrator or high privilege accounts should not contain information that identifies them as admins. All the IDs should be distinctive with appropriate	Rectified.

#	Observation	Risk	Affected Nodes	Risk and Vulnerabilities	Control Recommendations	Management Comments
	account has higher privileges level than the standard user.			attacker has obtained the configuration from the device they may be able to identify authentication credentials that could then be used to gain access to other network devices.	user name. It would be appropriate if default admin accounts are not used rather they should be disabled if possible. Admin users should use their own unique credentials to access the system(s) so that their activities are properly logged and accountability will be established.	
5	During review, it has been noted that logging was disabled on the interface ACL of deny statements.	Moderate	10.1.100.90 (Fortinet 60D) 10.1.100.40 (Juniper SSG20)	Auditing and logging are key components of any security architecture. It is essential for security personnel to know what is being done, attempted to be done, and by whom in order to compile an accurate risk assessment. Auditing the actions on network devices provides a means to recreate an attack, or identify a configuration mistake on the device.	Configure interface ACLs to log all deny statements.	Rectified.
6	During assessment, we noted that “Guest” group account exists in Fortinet 60D firewall which contains multiple users with “guest” access rights.	Moderate	10.1.100.90 (Fortinet 60D)	Guest Group account is configured and used on a network device which directly indicates to a potential threat. Attackers can easily breach this kind of account by brute force .If group accounts are not changed when someone leaves the group, that person could possibly gain control of the network device. Having group account does not allow for proper auditing of who is accessing or changing the network.	Guest accounts should be disabled or renamed with a unique ID hence guest user could privileged escalate to root user or super user by obtaining all his credentials.	Rectified.
7	SNMP Agent Default Community Name (public) (CVE-1999-0517)	Moderate	172.16.72.1 (Core Switch)	It is possible to obtain the default community name of the remote SNMP server. An attacker may use this information to gain more knowledge about the remote host,	Disable the SNMP service on the remote host if you do not use it. Either filter incoming UDP packets going to this port, or change the default	Rectified.

#	Observation	Risk	Affected Nodes	Risk and Vulnerabilities	Control Recommendations	Management Comments
				or to change the configuration of the remote system (if the default community allows such modifications).	community string.	
8	During the review it has been observed that no pre-login banner was configured in juniper Fortinet 60D firewall.	Low	10.1.100.90 (Fortinet 60D) 10.1.100.40 (Juniper SSG20)	A pre-logon banner message is often overlooked when configuring a device, but it is an important security setting which could potentially discourage an uncommitted attacker from proceeding any further. A pre-logon banner message should be configured to warning any potential attacker against unauthorized access and the consequences. Furthermore if legal proceedings are executed against an attacker it would be easier to prove intent on behalf of the attacker if they were first warned against unauthorized access.	We recommend that a carefully worded legal banner that warns against unauthorized access should be configured.	Rectified.
9	During review of configuration file, it has been observed that that clear text "TELNET" Service is enabled	Moderate	10.1.100.40 (Juniper SSG20)	Due to the lack of encryption provided by the Telnet protocol, an attacker who is able to monitor a Telnet session would be able to view all of the authentication credentials and data passed in the session. The attacker could then attempt to gain access to the device using the authentication credentials extracted from the session and potentially gain access under the context of that user. Since Telnet is commonly used for network device administration this could gain the attacker an administrative level of access.	A cryptographically secure alternative, such as SSH, should be used instead. If Telnet has to be used then, network filtering should be employed to restrict access to the service from only those specific devices that need the access.	Rectified.

8. Review of Business Continuity, Disaster Recovery Plans and Testing Reports

S#	Observation	Risk	Risk and Vulnerabilities	Control Recommendations	Management Comments
1	STP Application including backend database is not currently covered in the JS Bank BCP / DR Plan. Hence, currently there is no active DR site available for STP Application in the event of disaster. Further, current STP Application backup and recovery strategy is not approved by the JS Management.	Severe	In the absence of proper BC / DR plan for STP, resuming services related to STP will not be possible in the event of disaster.	Management should develop Business continuity and disaster plans for STP Application.	It is new application and will be added to DR and BCP policy.

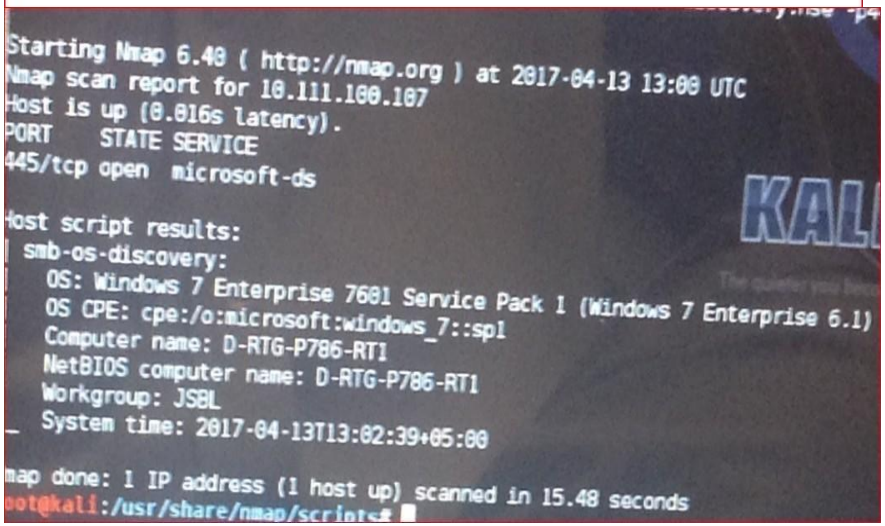
9. Annexure A – Vulnerability Assessment

9.1 A1: Server Message Block (SMB) Protocol Version 1 Unspecified RCE (credentialed check)

Hosts

10.111.100.107 (tcp/445)

The remote host supports SMBv1.



9.2 A2: Microsoft Windows Remote Desktop Protocol Server Man-in-the-Middle Weakness

Hosts

10.111.100.107 (tcp/3389)

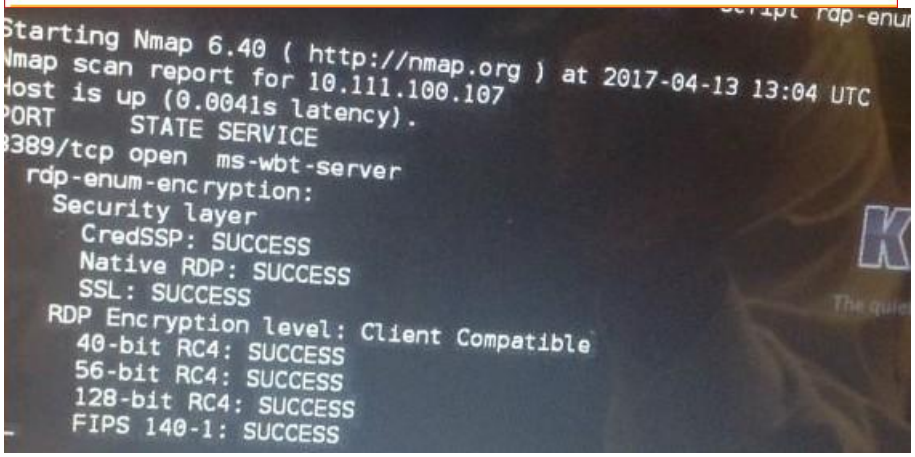
9.3 A3: Terminal Services Encryption Level is Medium or Low

Hosts

10.111.100.107 (tcp/3389)

```
The terminal services encryption level is set to :

2. Medium
```



9.4 A4: Terminal Services Doesn't Use Network Level Authentication (NLA) Only

Hosts

10.111.100.107 (tcp/3389)

```
Nessus was able to negotiate non-NLA (Network Level Authentication) security.
```

9.5 A5: SSL Version 2 and 3 Protocol Detection

Hosts

10.1.100.40 (tcp/443)

```
- SSLv2 is enabled and the server supports at least one cipher.

- SSLv3 is enabled and the server supports at least one cipher.
```

9.6 A6: SSL DROWN Attack Vulnerability (Decrypting RSA with Obsolete and Weakened encryption)

Hosts

10.1.100.40 (tcp/443)

```
The remote host is affected by SSL DROWN and supports the following
vulnerable cipher suites :

High Strength Ciphers (>= 112-bit key)

SSLv2
RC4-MD5 Kx=RSA Au=RSA Enc=RC4(128) Mac=MD5

The fields above are :

{OpenSSL ciphername}
Kx={key exchange}
Au={authentication}
Enc={symmetric encryption method}
Mac={message authentication code}
{export flag}
```

9.7 A7: SSH Server CBC Mode Ciphers Enabled

Hosts

10.1.100.40 (tcp/22)

```
The following client-to-server Cipher Block Chaining (CBC) algorithms
are supported :

3des-cbc

The following server-to-client Cipher Block Chaining (CBC) algorithms
are supported :

3des-cbc
```

Hosts

10.1.100.90 (tcp/22)

```
The following client-to-server Cipher Block Chaining (CBC) algorithms
are supported :

3des-cbc
aes128-cbc
aes192-cbc
aes256-cbc
blowfish-cbc
cast128-cbc
rijndael-cbc@lysator.liu.se

The following server-to-client Cipher Block Chaining (CBC) algorithms
are supported :

3des-cbc
aes128-cbc
aes192-cbc
aes256-cbc
blowfish-cbc
cast128-cbc
rijndael-cbc@lysator.liu.se
```

9.8 A8: SSL RC4 Cipher Suites Supported (Bar Mitzvah)

Hosts

10.1.100.40 (tcp/443)

```
List of RC4 cipher suites supported by the remote server :

High Strength Ciphers (>= 112-bit key)

SSLv2
RC4-MD5 Kx=RSA Au=RSA Enc=RC4(128) Mac=MD5

TLSv1
RC4-MD5 Kx=RSA Au=RSA Enc=RC4(128) Mac=MD5

The fields above are :

{OpenSSL ciphername}
Kx={key exchange}
Au={authentication}
Enc={symmetric encryption method}
Mac={message authentication code}
{export flag}
```

9.9 A9: Password Transmitted over HTTP

```
POST / HTTP/1.1
Host: 10.111.100.107:8082
User-Agent: Mozilla/5.0 (Windows NT 6.1; WOW64; rv:52.0) Gecko/20100101 Firefox/52.0
Accept: text/html,application/xhtml+xml,application/xml;q=0.9,*/*;q=0.8
Accept-Language: en-US,en;q=0.5
Accept-Encoding: gzip, deflate
Referer: http://10.111.100.107:8082/
Cookie: ASP.NET_SessionId=jld0oosrqtniey2tbaudzqln
Connection: keep-alive
Upgrade-Insecure-Requests: 1
Content-Type: application/x-www-form-urlencoded
Content-Length: 400

__EVENTTARGET=&__EVENTARGUMENT=&__VIEWSTATE=%
2FwEPDwUKMTg3NTEzNDI2MQ9kFgICAw9kFgICCw8PFgIeB1Zpc2libGVoZGRkLWFKOyqcN7mD%
2BC9JV3WcewOYFhmmTzU1OMy4oxw7nMk%3D&__VIEWSTATEGENERATOR=C2EE9ABB&__EVENTVALIDATION=%
2FwEdAAQPZ3KQC6FzXZ4bBIDxCUuRshCT4q90vziZH2FxDPZECFwK8%2F1gnn25OldlRNyIedminihG6d%
2FXh3PZm3b5AoMQ%2BfpwKvv9c1X%2Bdj2S3EsCvuO0ylto3mfIdxcIvw%2BOLGM%
3D&userid=sec_checker&Password=123&btnLogin=LoginHTTP/1.1 302 Found
Cache-Control: private
Content-Type: text/html; charset=utf-8
Location: /admin_c/checkHome.aspx
Server: Microsoft-IIS/7.5
X-AspNet-Version: 4.0.30319
X-Powered-By: ASP.NET
Date: Thu, 13 Apr 2017 06:45:23 GMT
Content-Length: 7458

<html><head><title>Object moved</title></head><body>
```

10. Annexure B

10.1 B1 - UNAUTHORIZED IDs

S.No	USR_ID	USR_NME	ROLE_NME	DEPT_NME
1	7	ahmed	Viewer	Treasury
2	9	Faisal	Creator	Treasury
3	10	usama	Creator	Treasury
4	11	imad	Creator	Treasury
5	12	t_ah	Creator	Treasury
6	13	Ali	Authorizer	Treasury
7	14	Anwer	Viewer	Treasury
8	20	immad	Authorizer	Centralized Operations-COPS
9	23	musama	Viewer	Centralized Operations-COPS
10	25	Hafeez	Viewer	Treasury
11	26	Hafeez1	Creator	Treasury
12	27	shakil	Creator	Treasury
13	28	aus	Viewer	Treasury
14	29	soofi	Viewer	Treasury
15	33	SHAFEEZ	Viewer	Treasury
16	37	UsamaAli	Viewer	Treasury
17	44	yahooq00031	Viewer	Treasury
18	52	mazhar00074	Authorizer	Treasury
19	6	Usama	Viewer	Centralized Operations-COPS
20	8	sddasdasd	Authorizer	Centralized Operations-COPS
21	14	yaqoob0031	Viewer	Centralized Operations-COPS
22	7	ahmed	Viewer	ICU
23	13	shoaib	Viewer	Centralized Operations-COPS

EY Ford Rhodes Chartered Accountants
Assurance | Tax | Transactions | Advisory

EY Ford Rhodes Chartered Accountants is a member firm of Ernst & Young Global Limited. Ernst & Young is one of the leading professional services firm with a significant Fortune 500 client base across the world.

The Principal Office of EY in Pakistan is located at Progressive Plaza, Beaumont Road, Karachi.

Primary contact for Information Technology Risk & Assurance (ITRA) is Partner / Head of ITRA – Mr. Waqar Ahmed Khan, who can be reached at +92-21-111-111-3937 (Ext. 1506) and waqar.khan@pk.ey.com

© 2017 EY Ford Rhodes
All Rights Reserved